TLP:AMBER Restricted to the recipient's organization and its trusted clients/contractors on a need-to-know basis.

CYBER THREAT INTELLIGENCE REPORT

SonicWall SonicOS SSL-VPN SAML/MFA bypass added to CISA KEV

From **Cybersecurity Briefing** · 2026-11-08 to 2026-11-09 (24 hours; stretched to 2026-11-04 because the window was thin, and for the Indiana sections) · Briefing generated 2026-11-09

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261110-04	1.0 · 2026-11-10 08:05 EST	TLP:AMBER	United States
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-06	2026-11-09	CVE-2026-19868 (CVSS 7.1)	Nick Sturgeon

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 6 November 2026 SonicWall published advisory SNWLID-2026-0014 for CVE-2026-19868, an authentication enforcement flaw in the SonicOS SSL-VPN service. Where SSL-VPN logins are configured to use SAML, a user who holds valid credentials for a different (non-SAML) login method can sign in without going through the SAML identity provider, which also skips any multi-factor check the identity provider enforces. In practice, a VPN login that should require Okta or Microsoft Entra ID plus MFA can succeed with a password alone [S1] [S4] [S8]. SonicWall said its product security team investigated a report of potential exploitation, and CISA added the CVE to the Known Exploited Vulnerabilities catalog the same day with a federal due date of 20 November 2026 [S2] [S3] [S5].

Affected products are Gen7 firewalls (TZ, NSa, NSsp, NSv) on SonicOS 7.3.3-7015 and earlier and Gen8 firewalls (TZ, NSa, NSv) on 8.2.2-8015 and earlier, and only when SAML is enabled for SSL-VPN logins. Fixed builds are 7.3.4-7013 (Gen7) and 8.2.3-8015 (Gen8). SonicWall lists no workaround [S5] [S7] [S8]. The vendor scores the flaw 7.1 (privileges required: low); the CISA enrichment carried by NVD scores it 7.5 (no privileges required). Both rate attack complexity high. The EPSS score on 9 November was 0.006 (about the 50th percentile), which understates the risk given confirmed exploitation [S4] [S9] [S10] [S11].

This is not an unauthenticated bypass: the attacker must already have a working username and password for an account that can use an

alternate login method. That limits who can exploit it, but stolen and reused VPN passwords are common, and the point of SAML-enforced MFA is to stop exactly that case. No indicators of compromise, attacker identity, victim count, or post-access activity have been published by SonicWall, CISA or any security vendor, and it is not known whether exploitation began before the patch was available [S7] [S8]. CISA lists ransomware use as unknown [S2].

The same firmware fixes six other SonicOS flaws, none reported as exploited, including two 8.8-rated management-interface bugs (CVE-2026-107155 and CVE-2026-107154) and a 7.5-rated pre-authentication heap overflow in SSL-VPN (CVE-2026-82308) [S6] [S12]. Organizations should upgrade affected firewalls now, save device logs before rebooting, and compare recent SSL-VPN logins against identity provider sign-in logs; any VPN session without a matching SAML sign-in and MFA record should be treated as suspect and the account's credentials reset [S8] [S12].

Key judgments

LIKELY · LOW CONFIDENCE
Exploitation so far is likely limited and targeted rather than widespread, because the flaw needs valid credentials, has high attack complexity, is rated not automatable by CISA, and the only public evidence is a single report investigated by SonicWall. [S1] [S4] [S5] [S8]

LIKELY · MODERATE CONFIDENCE
Ransomware affiliates and access brokers that already work SonicWall SSL-VPN with stolen credentials will likely adopt this bypass against unpatched firewalls within weeks, given their record with earlier SonicWall MFA bypasses such as CVE-2024-12802 and the 2025 Akira intrusions. [S2] [S8]

VERY LIKELY · LOW CONFIDENCE
A technical write-up or patch-diff analysis that identifies the affected alternate login method and request sequence will very likely be published by a security research team in the coming weeks, which would lower the skill needed to exploit the flaw. [S8] [S9]

UNLIKELY · MODERATE CONFIDENCE
Organizations that patch but do not review past VPN logins against identity provider logs are unlikely to detect a prior compromise, because a bypassed login may look like a normal successful SSL-VPN session and no indicators have been released. [S8] [S9] [S12]

INDICATORS OF COMPROMISE

No indicators of compromise have been published by SonicWall, CISA or any security vendor as of 10 November 2026. The entries below are derived hunting pointers based on the described behavior, not observed attacker artifacts.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Successful SonicOS SSL-VPN login for a SAML-governed user with no matching identity provider (Entra ID, Okta or other) sign-in and MFA event at the same time`	Derived from the vulnerability description: the bypass lets a login complete through an alternate method without touching the SAML identity provider, so the firewall records a session that the identity provider never saw. Help Net Security and other write-ups recommend this cross-check.	DERIVED		[S1] [S8] [S12]
other	`SonicOS SSL-VPN authentication log entry showing a non-SAML method (local user, LDAP or RADIUS) for an account that should only sign in through SAML`	Derived: the flaw requires valid credentials for an alternate authentication method. Which methods are affected is not stated by the vendor, and it is not confirmed that SonicOS logs record the method used, so absence of such entries does not rule out abuse.	DERIVED		[S4] [S9]
port	`4433/tcp`	Derived: 4433 is the common default SonicOS SSL-VPN listening port (many deployments move it to 443). Use it to scope which internet-facing interfaces to review; it is not an attacker indicator.	DERIVED		[S1]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker starts with a valid username and password for an account on the firewall that can authenticate by a method other than SAML. How those credentials are obtained has not been reported. The attacker then signs in to the internet-facing SonicOS SSL-VPN service in a way that the firewall accepts under the alternate method, even though the SSL-VPN is configured to require SAML. Because the identity provider is never consulted, its MFA and conditional access policies are not applied, and the attacker receives a VPN session with that user's network access. The vendor has not published the request sequence, the affected alternate methods, or any post-access activity; the ATT&CK mapping below is an analyst assessment based on the advisory wording, not on observed intrusions.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1133 External Remote Services	Attacker logs in to the internet-facing SonicOS SSL-VPN service and obtains a remote-access session into the internal network. [S1] [S8] [S12]	Review SSL-VPN login events for unusual source countries, hosting-provider addresses, off-hours access and accounts that should not be connecting (former staff, service accounts).
Initial Access	T1078 Valid Accounts	Exploitation requires valid credentials for an account that can use an alternate (non-SAML) authentication method. The source of the credentials in the reported case is unknown. [S4] [S8] [S12]	Correlate each successful SSL-VPN login with an identity provider sign-in that satisfied MFA. Flag VPN sessions with no matching record and multiple failed logins followed by a success across several users.
Initial Access	T1190 Exploit Public-Facing Application	Attacker abuses the authentication enforcement flaw (CWE-308) in the SSL-VPN service so that SAML controls, including SAML-enforced MFA, are not applied to the login. [S1] [S2] [S4]	No request signature is public. Inventory firewalls on SonicOS 7.3.3-7015 or earlier and 8.2.2-8015 or earlier with SAML enabled for SSL-VPN, and treat them as exposed until patched.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

SonicWall SSL-VPN login with no matching Entra ID sign-in `KQL`

```
let window = 10m;
let vpn = CommonSecurityLog
| where TimeGenerated > ago(30d)
| where DeviceVendor =~ "SonicWall"
| where Activity has_any ("SSL VPN zone remote user login allowed", "SSLVPN") and Activity has "login allowed"
| extend User = tolower(coalesce(SourceUserName, DestinationUserName))
| where isnotempty(User)
| project VpnTime = TimeGenerated, User, SourceIP, Computer;
let idp = SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == 0
| where AppDisplayName has_any ("SonicWall", "SSL VPN", "SSLVPN")
| extend User = tolower(tostring(split(UserPrincipalName, "@")[0]))
| project IdpTime = TimeGenerated, User, IdpIP = IPAddress, AuthenticationRequirement;
vpn
| join kind=leftouter idp on User
| extend Matched = iff(isnotempty(IdpTime) and abs(datetime_diff('second', VpnTime, IdpTime)) <= 600, 1, 0)
| summarize Matched = max(Matched) by VpnTime, User, SourceIP, Computer
| where Matched == 0
| order by VpnTime desc
```

Assumes SonicWall syslog arrives as CEF in CommonSecurityLog and the SSL-VPN SAML application is registered in Entra ID. Adjust the Activity text, the enterprise application name and the user name normalization to match your environment. Results are VPN sessions the identity provider never saw.

SonicWall SSL-VPN logins without an Okta or other IdP sign-in `SPLUNK SPL`

```
index=firewall sourcetype=sonicwall* ("SSL VPN zone remote user login allowed" OR (sslvpn "login allowed"))
| eval user=lower(coalesce(usr, user, src_user))
| bin _time span=10m
| stats count AS vpn_logins values(src) AS src_ip BY _time user
| join type=left user _time
    [ search index=idp (sourcetype=OktaIM2:log eventType=user.authentication.sso outcome.result=SUCCESS target{}.displayName="*SonicWall*")
      | eval user=lower(mvindex(split('actor.alternateId', "@"), 0))
      | bin _time span=10m
      | stats count AS idp_logins BY _time user ]
| where isnull(idp_logins)
| table _time user src_ip vpn_logins
```

Index, sourcetype and field names are placeholders. The 10-minute bucket can miss matches that straddle a boundary; widen it or use transaction logic if false positives appear. Swap the subsearch for your identity provider's sign-in data.

SonicWall SSL-VPN login allowed from a new source for the user `SIGMA`

```
title: SonicWall SSL-VPN Remote User Login Allowed
id: 6d1f0c1e-2b7a-4c56-9a10-19868a000001
status: experimental
description: Flags successful SonicOS SSL-VPN logins for review and correlation with identity provider sign-in logs (CVE-2026-19868
hunting).
logsource:
  product: sonicwall
  service: firewall
detection:
  selection:
    message|contains:
      - 'SSL VPN zone remote user login allowed'
      - 'SSLVPN zone remote user login allowed'
  condition: selection
fields:
  - src_ip
  - user
  - message
falsepositives:
  - Legitimate VPN logins; this is a collection rule that must be correlated with IdP sign-in data
level: low
```

Collection rule only. The exact message text and event ID differ by SonicOS version; confirm against your own logs. Pair it with a baseline of each user's usual source addresses and with the identity provider correlation above.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
SonicWall SonicOS Gen7 (TZ 270-670, NSa 2700-6700, NSsp 10700-15700, NSv 270/470/870) with SAML enabled for SSL-VPN	7.3.3-7015 and earlier	7.3.4-7013 or later	CVE-2026-19868	7.1 (SonicWall) / 7.5 (CISA ADP, NVD)	0.00621 (about 50th percentile, 2026-11-09)	Yes (added 2026-11-06)	2026-11-20
SonicWall SonicOS Gen8 (TZ 80-680, NSa 2800-5800, NSv XS/S/M/L) with SAML enabled for SSL-VPN	8.2.2-8015 and earlier	8.2.3-8015 or later	CVE-2026-19868	7.1 (SonicWall) / 7.5 (CISA ADP, NVD)	0.00621 (about 50th percentile, 2026-11-09)	Yes (added 2026-11-06)	2026-11-20
SonicWall SonicOS Gen7 and Gen8, other flaws fixed in the same release (management interface, SSL-VPN, TACACS+ client, virtual appliances)	Gen7 7.3.3-7015 and earlier; Gen8 8.2.2-8015 and earlier	7.3.4-7013 / 8.2.3-8015	CVE-2026-107155, CVE-2026-107154, CVE-2026-82308, CVE-2026-77708, CVE-2026-77709, CVE-2026-19703	8.8, 8.8, 7.5, 5.9, 5.9, 5.2 (the last three scores come from a single smaller outlet)	Not checked	No	N/A

Immediate (0–24 hours)

- Inventory every SonicWall Gen7 and Gen8 firewall, record the full firmware build, and identify which have SSL-VPN enabled with SAML authentication (Users > Settings > SAML configuration; Network > SSL VPN > Server Settings). `IT OPS` [S7] [S12]
- Export and preserve firewall logs and a configuration backup before upgrading, since a reboot may clear on-box logs. `IT OPS` [S12]
- Upgrade affected firewalls to SonicOS 7.3.4-7013 or later (Gen7) or 8.2.3-8015 or later (Gen8). SonicWall lists no workaround; prioritize internet-facing SSL-VPN devices that use SAML. `IT OPS` [S1] [S5] [S7]
- Compare the last 30 to 90 days of successful SSL-VPN logins with identity provider sign-in logs and flag any VPN session with no matching SAML

sign-in and MFA record. `SOC` [S8] [S12]
- For any flagged account, reset the password, revoke active sessions and review what the VPN session reached. `SOC` [S8] [S9]

Short term (1–7 days)

- Audit firewall users and groups with SSL-VPN access. Remove or disable local, LDAP or RADIUS accounts that can sign in to SSL-VPN outside SAML, while keeping a separate administrative path that does not depend on SSL-VPN. `IT OPS` [S9]
- Check for recent configuration changes on the firewall: new local accounts, newly enabled authentication methods, new SSL-VPN group memberships. `SOC` [S9]
- Rotate passwords for accounts with SSL-VPN access where credential theft or reuse is suspected, and for any local firewall accounts. `IT OPS` [S8]
- Confirm the firewall management interface is not reachable from the internet, since the same release fixes two 8.8-rated management-interface flaws. `IT OPS` [S6] [S7]
- Report patch status and log review results to leadership before the 20 November KEV due date, which is a reasonable target for non-federal organizations as well. `LEADERSHIP` [S2] [S3]

Long term

- Forward SonicWall syslog and identity provider sign-in logs to a central log platform and keep a standing correlation that alerts on VPN sessions with no identity provider record. `SOC` [S8] [S12]
- Replace end-of-support Gen6 firewalls and set a firmware service level for edge devices (for example, KEV-listed fixes applied within 7 days). `LEADERSHIP` [S8]
- Evaluate moving remote access from SSL-VPN on the firewall to a zero-trust or identity-aware access service that enforces MFA and device posture independently of the edge device. `LEADERSHIP` [S8]

Workarounds & compensating controls

- Until patched, restrict SSL-VPN access to known source addresses or countries where the business allows it. This reduces exposure but is not a vendor-supported fix. `IT OPS` [S9]
- Until patched, disable SSL-VPN on devices where it is not needed, or temporarily remove non-SAML accounts from SSL-VPN access groups. `IT OPS` [S9]
- Raise alerting on new VPN source addresses, impossible-travel logins and VPN sessions followed by internal scanning or lateral movement. `SOC` [S8] [S12]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] SonicWall PSIRT: SNWLID-2026-0014 (SonicOS security advisory)
Published 2026-11-06 · A1 Completely reliable, confirmed by other sources
Primary vendor advisory. The page did not render to the fetch tool (script-driven page), so its content is taken from the CVE record and from press reports that quote it; verify directly in a browser.

[S2] CISA: Known Exploited Vulnerabilities catalog entry for CVE-2026-19868
Published 2026-11-06 · A1 Completely reliable, confirmed by other sources
Added 2026-11-06, due 2026-11-20, ransomware use Unknown, CWE-308, cites BOD 26-04.

[S3] CISA: CISA Adds One Known Exploited Vulnerability to Catalog
Published 2026-11-06 · A1 Completely reliable, confirmed by other sources
Alert announcing the KEV addition based on evidence of active exploitation.

[S4] CVE Program (MITRE): CVE-2026-19868 record
Published 2026-11-06 · A1 Completely reliable, confirmed by other sources
CNA description, affected versions, CWE-308, CISA ADP score 7.5 and SSVC (exploitation active, not automatable, partial technical impact).

[S5] BleepingComputer: SonicWall warns of new SSL-VPN MFA bypass flaw exploited in attacks
Published 2026-11-06 · B2 Usually reliable, probably true
Versions, vendor statement, researcher credit, no workaround.

[S6] The Hacker News: CISA flags SonicWall SonicOS MFA bypass
Published 2026-11-09 · B2 Usually reliable, probably true
Names three of the other CVEs fixed in the release and their scores.

[S7] SecurityWeek: SonicWall Patches Exploited SonicOS Vulnerability That Weakens VPN Logins
Published 2026-11-09 · B2 Usually reliable, probably true
Affected model families; notes it is unclear whether the flaw was exploited as a zero-day. Publication date approximate.

[S8] Help Net Security: Exploited SonicWall SSL-VPN flaw lets attackers bypass SAML-enforced MFA (CVE-2026-19868)
Published 2026-11-09 · `B2` Usually reliable, probably true
Log review advice, Gen6 status, context on earlier SonicWall MFA bypass abuse.

[S9] Ostorlab: SonicWall SSLVPN SAML Bypass, Exploited in the Wild (CVE-2026-19868)
Published 2026-11-09 · `C3` Fairly reliable, possibly true
Vendor CVSS vector difference (PR:L vs PR:N); the attack flow and interim mitigations are the author's inference, not vendor guidance. Publication date approximate.

[S10] OpenCVE (NVD data mirror): CVE-2026-19868
Published 2026-11-06 · `B2` Usually reliable, probably true
Used for NVD fields because the NVD page did not render. NVD last modified 2026-11-09.

[S11] FIRST: EPSS API result for CVE-2026-19868
Published 2026-11-09 · `A2` Completely reliable, probably true
EPSS 0.00621, percentile 0.50063.

[S12] Oflight: SonicWall CVE-2026-19868 (SSLVPN SAML and MFA Bypass): How to Check Exposure and Fix It
Published · `C3` Fairly reliable, possibly true
Only source found for the full seven-CVE list with scores and the model list; three CVE IDs match The Hacker News. Publication date not captured.

[S13] Security Affairs: U.S. CISA adds SonicWall SonicOS SSLVPN flaw to its Known Exploited Vulnerabilities catalog
Published 2026-11-07 · `B2` Usually reliable, probably true
Corroborates the KEV listing; cites BOD 22-01 where the KEV entry cites BOD 26-04.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-08-14	CVE-2026-19868 reserved by SonicWall.	[S4] [S10]
2026-11-06	SonicWall publishes advisory SNWLID-2026-0014 with fixed builds 7.3.4-7013 and 8.2.3-8015 and states it investigated a report of potential exploitation.	[S1] [S5]
2026-11-06	CISA adds CVE-2026-19868 to the KEV catalog; federal due date 2026-11-20.	[S2] [S3]
2026-11-07	CVE record updated with CISA enrichment (CVSS 7.5, exploitation active).	[S4]
2026-11-09	Follow-up press coverage; NVD record last modified. No indicators or technical analysis published.	[S6] [S8] [S10]
2026-11-20	KEV remediation due date for federal civilian agencies.	[S2]

Relevance to Indianapolis, Indiana & managed clients

SonicWall TZ and NSa firewalls are widely used by Indiana small and mid-size businesses, school corporations, local government offices, clinics and manufacturers, often as the only remote-access gateway and often managed by an outside IT provider. Organizations that moved SSL-VPN logins to SAML with Entra ID or Okta did so to add MFA and satisfy cyber insurance or compliance requirements (HIPAA for healthcare, CJIS for public safety, state guidance for local government); this flaw can silently undo that control for any account that also has a local, LDAP or RADIUS login on the firewall. For managed IT service clients the practical steps are: confirm firmware builds across the whole managed firewall fleet, patch internet-facing SAML SSL-VPN devices first, and run the VPN-to-identity-provider login comparison for each tenant. Local government and K-12 entities are not bound by the federal deadline, but 20 November is a sensible target. Small organizations that do not centralize firewall logs should export them before upgrading, because they may be the only record of past logins. No Indiana victims have been reported.

Intelligence gaps

- No indicators of compromise, attacker infrastructure or request patterns have been published.
- The identity of the actor, the number of victims and what was done after access are unknown.
- It is not known whether exploitation occurred before the patch was released (zero-day) or how the reporter observed it.
- SonicWall has not said which alternate authentication methods (local, LDAP, RADIUS, other) enable the bypass, or whether SonicOS logs show the

method used for each login.
- CISA lists ransomware campaign use as Unknown; watch for a change in that field.
- The vendor advisory page could not be read directly by the research tooling; advisory details here rely on the CVE record and press reports that agree with each other.
- The full list and scores of the six other CVEs comes partly from a single smaller outlet; confirm against the advisory.
- Watch for technical analysis from Rapid7, watchTowr, Huntress, Arctic Wolf or ReliaQuest, and for any SonicWall knowledge base article with log guidance.

Other notes

- CVSS differs by source: SonicWall scores 7.1 with privileges required set to low; the CISA enrichment used by NVD scores 7.5 with no privileges required. Both use high attack complexity and changed scope.
- The NVD configuration data lists version boundaries (7.3.4-7015 and 8.2.2-8015 as end-excluding) that do not match the vendor's fixed builds; follow the vendor's fixed versions (7.3.4-7013 and 8.2.3-8015).
- The KEV entry cites BOD 26-04 and its forensic triage requirements; one press report cites the older BOD 22-01.
- The flaw was reported by Ryan Harris of The Electronic Office, an IT services provider.
- Gen6 firewalls are not listed as affected but are end of support.
- This item is separate from the SMA1000 flaws (including CVE-2026-102255) and the unpatched end-of-life GMS flaws (CVE-2026-109593, CVE-2026-109594) reported earlier.
- The interim mitigations listed under compensating controls come from third-party analysis and analyst judgment; SonicWall states there is no workaround.

CTI-20261110-04 v1.0 · Generated 2026-11-10 08:05 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:AMBER Restricted to the recipient’s organization and its trusted clients/contractors on a need-to-know basis.